Design Analysis Report

Digital Document Verification System (DDVS) - Version 1.0

Department of Computer Science and Engineering, KIET Group of Institutions (KIET Deemed to be University)

Prepared by: Divya Kumari (202401100200133), Divyanshi Jaiswal (202401100200134), Divyanshi Khemani (202401100200135), Divyanshu Gupta (202401100200136)

Basis: SRS Version 1.0 (31 August 2026). Requirement IDs (FR-xx, NFR-xx) refer to that document.

1. Scope and design goals

DDVS lets an approved Issuing Organization register a PDF document (storing metadata and a SHA-256 hash and issuing a unique verification ID with an optional QR code) and lets any verifier check a document by ID, QR value or file upload. Possible results: **Verified, Invalid, Not Found, Tampered**. Design goals, taken from the SRS: correctness of the four-way result (FR-26 to FR-31), tamper detection by hash comparison only (FR-32 to FR-35), role-based access (NFR-07), full audit trail (FR-37, FR-49), and a modular code base (NFR-17). The system uses no blockchain, AI, OCR or biometrics (SRS 2.5).

2. Architecture

Three-tier web architecture (SRS 2.1): browser UI, application server exposing a REST/JSON API over HTTPS, and a relational database plus private file storage. The server is organised into independent modules behind one gateway that enforces session, role-based access control and server-side input validation (NFR-07, NFR-11).

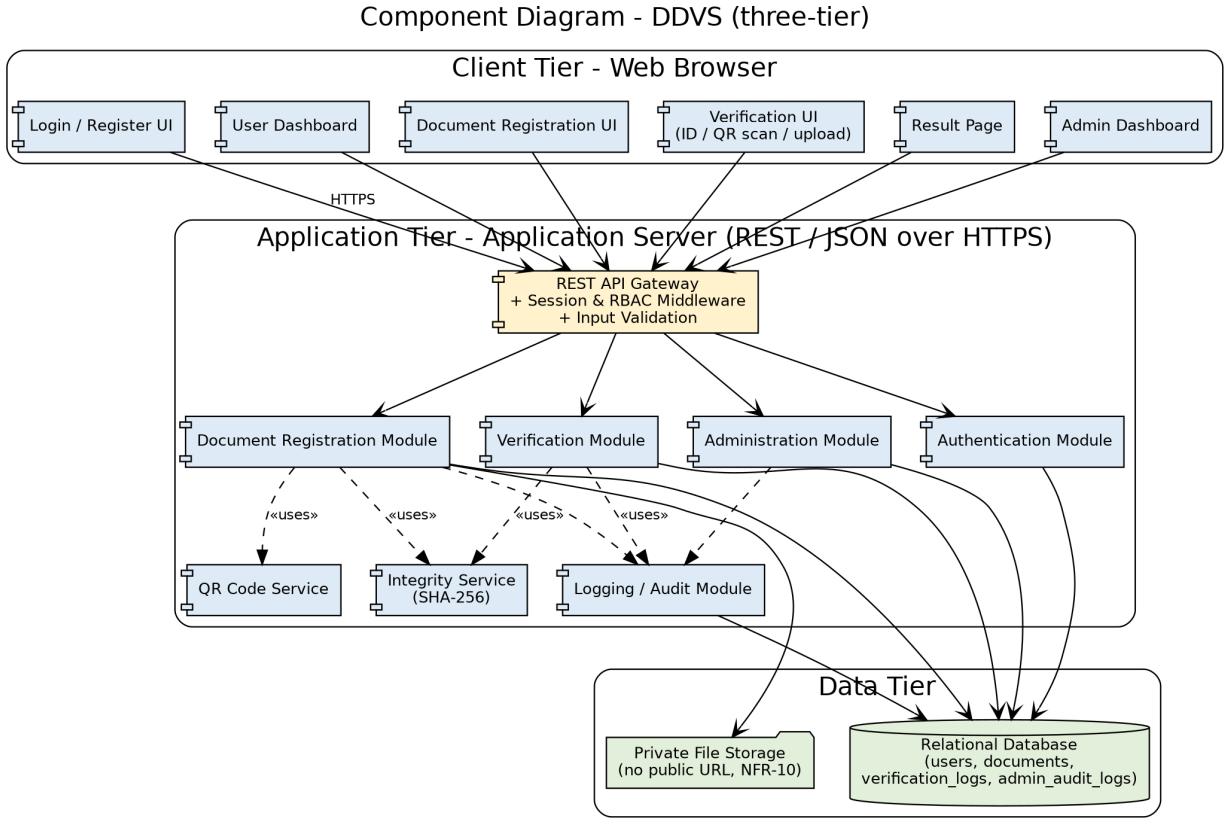


Figure 1 - Component diagram (see Component Diagram.pdf).

2.1 Module responsibilities and requirement coverage

Module	Responsibility	Requirements
REST gateway + RBAC middleware + validation	Session handling, 30-min inactivity timeout, role checks, input sanitisation, HTTPS only	FR-08, FR-09, FR-11, NFR-06, NFR-07, NFR-09, NFR-11
Authentication Module	Register, login (generic error), logout, change password, bcrypt hashing, lockout after 5 failures / 15 min, issuer request in PENDING state	FR-01 to FR-07, FR-10, FR-12, NFR-08, NFR-13
Document Registration Module	Mandatory-field check, file type (PDF) and size (10 MB) check, unique ID generation, store record, list own documents	FR-13 to FR-16, FR-18 to FR-21, NFR-05
Integrity Service (SHA-256)	Single hash routine used for registration and verification so both always use the same algorithm	FR-15, FR-32, FR-33
QR Code Service	Encode verification ID as QR; decode scanned/entered value to an ID	FR-17, FR-23
Verification Module	Format validation, lookup, revoked check, hash comparison, result mapping, no metadata on Not Found	FR-22 to FR-31, FR-34, FR-35

Module	Responsibility	Requirements
Logging / Audit Module	One verification_logs row per attempt; admin_audit_logs row per admin status change; read-only for non-admins	FR-36 to FR-42, FR-49, NFR-12
Administration Module	Approve/reject issuer requests, search/disable/enable users, search/revoke documents, filtered global history	FR-43 to FR-48

3. Data design

Four tables with enforced referential integrity (SRS 6.1). Revoked records are kept, never physically removed by a normal action, so a revoked ID answers Invalid rather than Not Found (SRS 6.2, NFR-04).

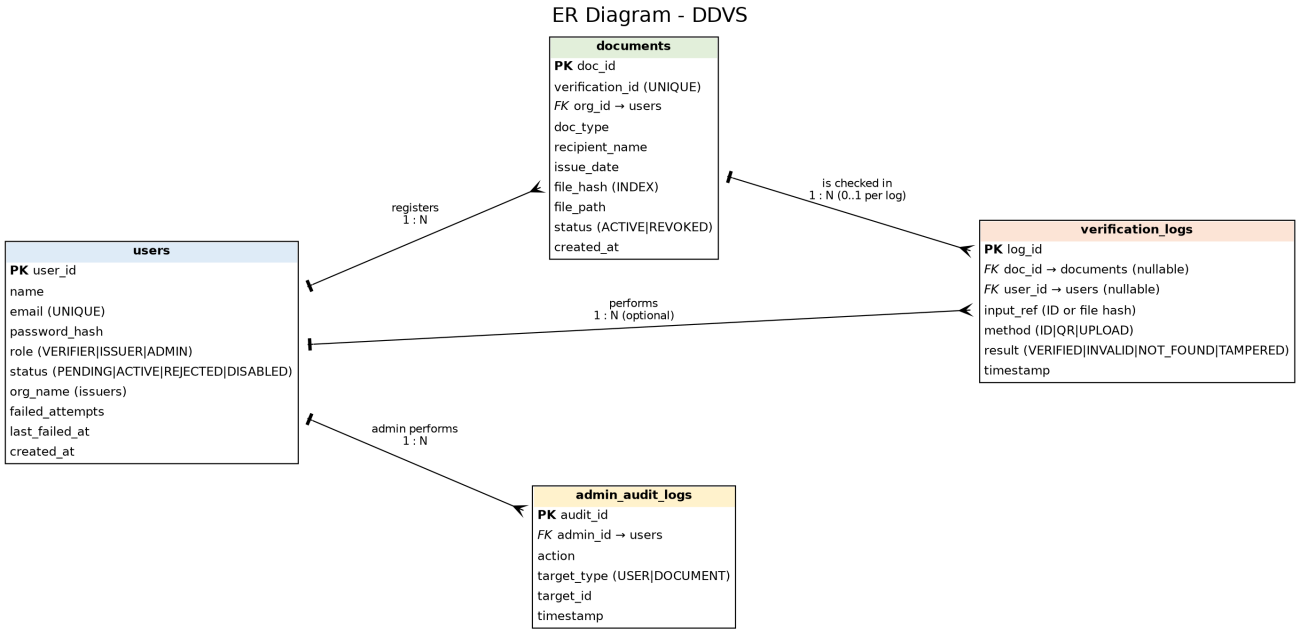


Figure 2 - ER diagram (see ER Diagram.pdf).

Table	Key columns	Constraints / indexes
users	user_id, name, email, password_hash, role, status, org_name, failed_attempts, last_failed_at	email UNIQUE; role in (VERIFIER, ISSUER, ADMIN); status in (PENDING, ACTIVE, REJECTED, DISABLED)
documents	doc_id, verification_id, org_id, doc_type, recipient_name, issue_date, file_hash, file_path, status	verification_id UNIQUE; org_id FK to users; INDEX on file_hash (file-only lookup); status in (ACTIVE, REVOKED)
verification_logs	log_id, doc_id, user_id, input_ref, method, result, timestamp	doc_id and user_id nullable (Not Found / anonymous); no UPDATE or DELETE for non-admin roles (FR-41)
admin_audit_logs	audit_id, admin_id, action, target_type, target_id, timestamp	admin_id FK to users; insert-only

4. Behavioural design

Verification algorithm (Activity Diagram.pdf, Sequence Diagram.pdf, implemented in src/ddvs_core.py):

1. Validate ID format (pattern DDVS-XXXXXXXXXXXX); malformed input is rejected before any lookup (FR-25).

2. Look up the record by verification ID (or, for file-only upload, by file_hash).

3. No record: result Not Found, no metadata returned (FR-26, FR-31).

4. Record revoked: result Invalid, regardless of hash (FR-29, Business Rule 6).

5. File supplied and SHA-256(file) differs from stored hash: result Tampered (FR-28, FR-34); otherwise Verified with non-sensitive metadata (FR-27).

6. Write one verification_logs row for every attempt and return the result (FR-37, FR-38).

State models (State Transition Diagram.pdf): document record (ACTIVE, REVOKED, DELETED), account (PENDING, ACTIVE, REJECTED, DISABLED, LOCKED), session, and verification request. **Data flow** (Dataflow

Diagram L0.pdf and Dataflow Diagram.pdf): context level with three external entities, level 1 with processes 1.0 Manage Accounts, 2.0 Register Document, 3.0 Verify Document, 4.0 Maintain Verification Log, 5.0 Administer System and stores D1 to D4. **Use cases and classes**: use case diagram.pdf and class diagram.pdf.

5. Interface design (REST, JSON over HTTPS)

Endpoint	Role	Purpose	FR
POST /api/auth/register	Public	Create general user	01-03
POST /api/auth/login	Public	Login, lockout, session	05, 06
POST /api/auth/logout; /change-password	Auth	End session; change password	10, 12
POST /api/org-requests	Public	Request issuer account (PENDING)	07
POST /api/documents	Issuer	Register document (multipart: metadata + PDF)	13-16, 18, 20, 21
GET /api/documents	Issuer	List own documents	19
GET /api/documents/{vid}/qr	Issuer	QR code for verification ID	17
POST /api/documents/{vid}/revoke	Issuer (own), Admin	Mark revoked	29, 48
POST /api/verify/id; /verify/qr; /verify/upload	Public*	Verify by ID, QR value, or file (+ optional ID)	22-24, 25-31, 32-36
GET /api/history	Auth	Own verification history	39
GET /api/admin/history?from&to;&result;	Admin	All history, filtered	40, 42
GET /api/admin/org-requests; POST .../{id}/approve|reject	Admin	Review issuer requests	43, 44
GET /api/admin/users?q; POST .../{id}/disable|enable	Admin	Search and disable/enable accounts	45, 46
GET /api/admin/documents?q	Admin	Search document records	47

*Verification needs no login unless the deployment restricts it (FR-30).

6. Security design

Concern	Design decision	Req.
Passwords	bcrypt with per-password salt; generic login error; policy min 8 chars with letter and digit	FR-03, 04, 06, NFR-08
Brute force	failed_attempts and last_failed_at; lock at 5 failures in 15 min	NFR-13
Transport	TLS on all client-server traffic	NFR-09
Access control	Role claim checked in middleware on every protected route	NFR-06, 07
Uploaded files	Stored outside web root; served only through authorised handlers; type and size validated	NFR-05, 10
Injection / XSS	Parameterised queries, server-side validation, output encoding	NFR-11
Audit	Insert-only verification and admin audit tables	NFR-12, FR-41

7. Verification and testing

The reference module and its 12 unit tests demonstrate the core logic end to end (all pass). Complexity and Halstead results are in Halstead_Metrics_Analysis_Matrix.pdf (maximum cyclomatic complexity 7).

Test	Scenario	Expected	FR
T01	Valid ID, no file	Verified	27
T02	Valid ID, original file	Verified	27, 33
T03	Valid ID, modified file	Tampered	28, 34
T04	Well-formed unknown ID	Not Found	26, 31
T05	Malformed ID	Rejected before lookup	25
T06	Revoked record, original file	Invalid	29, 48
T07	Revoked record, modified file	Invalid (revocation takes precedence)	29
T08	File only: registered / unknown file	Verified / Not Found	24
T09	Registration with a missing mandatory field	Rejected, field named	14
T10	Non-PDF file; file over 10 MB	Rejected	20, 21
T11	50 registrations	50 distinct IDs	16

Test	Scenario	Expected	FR
T12	Every attempt (found or not)	One log entry each	37

8. Design decisions and points to confirm

- **Revocation vs. tamper precedence.** FR-29 and Business Rule 6 require Invalid for a revoked record regardless of hash, but the Appendix B activity description tests the hash first. This design follows FR-29 (revoked check first). If your evaluator expects the Appendix B order, swap steps 4 and 5 in section 4 and in verify_document().

- **File-only verification (FR-24).** Without an ID the record is found through the indexed file_hash: a match gives Verified, no match gives Not Found. Tampered can only be reported when an ID identifies the original record.

- **Reinstating a revoked document.** The SRS calls revocation a reversible status change (NFR-04) but names no role; this design allows an Administrator to reinstate.

- **Technology stack.** The SRS leaves it open (SRS 2.4). The reference implementation is Python; the design is neutral between Node.js, Java and Python with MySQL or PostgreSQL.

- **Use case diagram.** An abstract actor 'User' groups Log In, Log Out/Change Password, Verify Document and View Own Verification History, which all three actors share.